DealWatch Agent

Challenge 1 · Blast Radius Zero · Pattern B: sandboxed browser use

- An AI agent that watches VPS deal pages for you.
- Every click happens inside a disposable, gVisor-isolated browser sandbox on Vultr.
- Live demo: https://202-182-108-36.sslip.io
- Code: github.com/huangcong9911/dealwatch-agent

The problem

- Cheap VPS deals and promo codes appear and vanish within hours across dozens of sites.
- Watching them by hand is tedious.
- Letting an agent browse the open web is dangerous: third-party scripts, and pages that hide prompt injections telling the agent to leak its keys or attack its own host.

How it works

- Plan: the LLM turns a goal into a JSON plan using only 5 allow-listed actions (goto, click_text, scroll, wait, extract).
- Dispatch: a fresh Docker container under gVisor runs headless Chromium (Playwright) with no secrets.
- Verify: the model reads the screenshot + text, extracts deals and flags injection.
- Diff + Approve: only new deals are shown, and a human approves before any alert. Watches repeat every 12 h.

Architecture on Vultr

- Vultr Cloud Compute VM (Tokyo, Ubuntu 24.04) hosts everything: Caddy HTTPS, FastAPI control plane, SQLite, the sandbox runtime and the egress firewall.
- LLM: OpenAI-compatible endpoint. The live demo uses a local model (qwen2.5:3b via Ollama) on the same Vultr VM; one env var switches it to Vultr Serverless Inference.
- The model key/endpoint lives only on the host, never in the sandbox.

Containment design

- Process: gVisor runsc, non-root, cap-drop ALL, no-new-privileges, read-only root FS, no Docker socket.
- Secrets: sandbox starts with an empty environment; a self-test scans it every run.
- Network: dedicated bridge + iptables chain blocks cloud metadata, private ranges, SMTP and the host itself; route guard enforces the vendor allow-list.
- Resources: 900 MB RAM, 1 vCPU, 512 PIDs, 90 s cap. Lifecycle: docker run --rm, verified destroyed.

The containment moment

- A fake Black-Friday page hides a prompt injection and runs JS that tries to reach the metadata service, the control plane and an exfiltration server.
- Result: every request blocked; metadata TCP, host control plane, host SSH, root-FS write, Docker socket and env-secret probes all CONTAINED.
- The model refuses the fake "$0.01 forever" deal, and the container is destroyed.

What's next

- More vendors and price-history charts.
- Telegram / email alerts after approval.
- Per-watch budgets and a stricter vision cross-check.
- Try it: https://202-182-108-36.sslip.io